

Individual Contribution Reflection

Tom Tian (540180866)

COMP4347 / COMP5347 Assignment 2: MERN Quiz Game (variation: Review Mode after completion)

Subsystem D: System Integration, Validation & Robustness (group-of-four mandated role, spec §11.1)

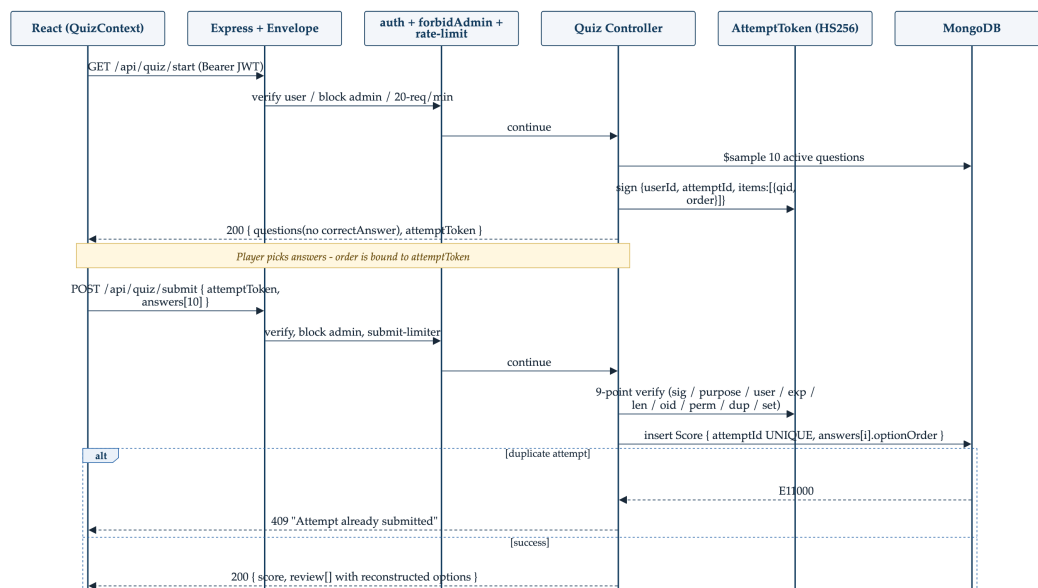
1. Subsystem ownership. I took Subsystem D: System Integration, Validation & Robustness. In our split, Tracy led Auth, Raven led quiz/review/leaderboard, and Allen led admin CRUD. My job was to join those parts and keep the API, UI, tests, and docs saying the same thing. The concrete work was: (a) the shared `{success,data?,error?}` envelope and 5xx-sanitising error handler; (b) the signed `attemptToken` checks in §2; (c) global hardening with `helmet`, `express-mongo-sanitize`, `CORS` allow-list, 1 MB body cap, and rate limiters; (d) Swagger UI at `/api-docs` and the matching Postman collection; (e) the React shell, `ThemeContext`, route guards, and `ActiveQuizNavigationGuard` in `App.jsx:28-115`; (f) 6 backend and 4 frontend test suites (**29 + 13 passing**); (g) the idempotent Mongo seed and root npm run demo bootstrap. 19 source files carry the Subsystem D - Integration, Robustness & Documentation (Tom Tian) header, so the ownership claim is easy to check with `rg`.

2. Major technical challenge: securing the shuffled-attempt contract. The issue I spent the most time on was option order. `/start` shuffles answers, `/submit` still has to mark the original answer correctly, and `/history/:id` has to show the same order the player saw. If we trusted client indices, or sent `correctAnswer` at `/start`, the quiz would be easy to tamper with and Review Mode would be unreliable. While stabilising the tests I found one bad assumption: `api.test.js` was effectively relying on `correctAnswer === 0` (fixed in bba8b06). I fixed this by signing a JWT `attemptToken` at `/start`. The token stores the option permutation, question IDs, user ID, and a `crypto.randomUUID()` attempt ID; the same permutation is saved later as `Score.answers[i].optionOrder` (73d24c6). The verifier rejects nine cases: bad signature, wrong purpose, wrong user, expired token, wrong length, malformed ObjectId, invalid permutation, duplicate qids, and qid-set mismatch. Replay protection is also layered: frontend `submitOnceRef`, controller pre-check, MongoDB `err.code === 11000` catch, and a unique partial index on `Score.attemptId`. Scoring then just maps the visible option back to the stored original index:

```
// backend/src/utils/quizAttemptToken.js:45-57, signed at /start
const attemptId = crypto.randomUUID();
const payload = {
  purpose: 'quiz_attempt', userId: String(userId), attemptId,
  items: questions.map(q => ({ qid: String(q._id), order: q.optionOrder })),
};
const token = jwt.sign(payload, getJwtSecret(), { expiresIn: ATTEMPT_TOKEN_TTL_SECONDS });

// backend/src/controllers/quiz.controller.js:149-151, scoring at /submit
const originalIndex = item.order[ans.selectedAnswer]; // visible idx -> stored idx
const isCorrect = originalIndex === question.correctAnswer;
```

3. Sequence diagram for a secured Review Mode attempt (Mermaid source rendered to PNG with `mmdc`; source kept in `.tools/reflection-build/`).



4. Variation design decisions (Review Mode). I made three integration choices for the Review Mode variation. (i) *Store optionOrder, not a full frozen question snapshot.* A full snapshot would save old typos forever, make `Score` documents larger, and make admin edits harder to reason about. Saving the 4-item permutation is enough to replay the attempt order, while the live `Question` remains the main record; if a question is deleted, review uses a `[Question deleted]` placeholder (`quiz.controller.js:271-282`). (ii) *Remove correctAnswer at /start.* `toStartQuizPayload` removes it, and `submit` checks `item.order[selected] === question.correctAnswer`. This keeps scoring on the backend. (iii) *Do not add a Quiz collection.* Per Ed #182, attempts are generated dynamically. The `attemptToken` is enough to bridge `start`→`submit`, so abandoned attempts do not need database rows.

5. Git commit history analysis. 38 non-merge commits on origin/final across two aliases (Tom Tian = 34; early Tom_Tian = 4; both documented in README.md “Git Workflow”). 14 representative commits below, each linking to a commit on Sydney GitHub Enterprise.

Hash	Focus	Technical evidence (what changed + why it matters)
7a61d82	Project bootstrap	Established the monorepo layout, root scripts (install:all, dev, seed, demo), .env.example files, and the initial .gitignore. Sets up the install/run path used during marking.
eb118b5	Shared React app shell	Added React Router shell, AppShellNavbar that swaps Player/Admin/Public navbars by route, and the ProtectedRoute/ProtectedAdminRoute wrappers consumed by every page.
6686eae	Seed + integration tests	Idempotent seeds/seed.js (1 admin + 2 players + 10 active questions; safe to re-run) and tests/api.test.js for the auth + quiz happy path.
972fc77	D-owned QA alignment	Reconciled validators.test.js / errorHandler.test.js / envelope.test.js with the delivered controller behaviour; removed stale fixtures that were masking real diffs.
160ac65	Risk note (no code crossover)	Documented a leaderboard/auth QA risk in writing only, deliberately leaving A/B code untouched. Keeps the local-ownership boundary agreed to in AGENTS.md.
bba8b06	Shuffled-answer test lock	Rewrote api.test.js to derive the visible index from the live /start response instead of asserting correctAnswer === 0. Closes the test blind spot that motivated S2.
4a8fe22	Swagger / Postman alignment	Synced the leaderboard and auth OpenAPI annotations with the actual response envelope, including the 401/429 negative paths, so the two API doc sets stay in sync.
d0d07f6	Quiz error catalogue	Documented every 400/401/403/409/429 path on /api/quiz/* in Swagger so the negative-path contract can be read without opening the controller.
73d24c6	Signed attempt integrity	Added quizAttemptToken.js, the 9-check verifier, the Score.attemptId unique partial index, and frontend submitOnceRef. Added tests for tampered, wrong-user, replayed, and expired tokens. This was my main robustness change.
fd08cc8	Admin ↔ player boundary	Added the forbidAdminQuiz middleware and the frontend <ProtectedRoute blockAdmin>. Admin JWTs now receive 403 on /api/quiz/*, and players are redirected away from /admin; symmetric access control on both layers.
06697e1	Active-quiz navigation guard	ActiveQuizNavigationGuard intercepts beforeunload, popstate, and document-level link clicks while hasActiveQuiz === true. Prevents accidental progress loss and the refresh-until-easy-question pattern.
a6e4ad7	Rate-limit split + API root	Separated registerLimiter from loginLimiter so the register endpoint cannot be starved by login probing. Exposed /api root with version metadata.
24ad7e7	Unified “new run” UX	Centralised the post-quiz “play again” reducer action so Result, History, and Review pages all trigger the same QUIZ_RESET/QUIZ_ERROR_RESET flow. Removed three small context-state bugs at the same time.
f5d3d98	Final reverse-mapping lock	Added a regression test that constructs 10 deliberately-wrong answers, submits them, and asserts score === 0; locks the reverse-mapping invariant before the final merge to final.

6. Reflection ↔ Spec §11 compliance map. Every rubric-mandated element of the Individual Reflection is covered above; this table is the index to where.

Spec §11 mandate	Where	Concrete evidence anchor
Subsystem responsibility + how implemented	§1	7 itemised scope buckets (a)–(g) anchored to file paths, test counts, and middleware names.
≥1 major technical challenge with code snippets <i>or</i> commit links	§2	9-line excerpt from quizAttemptToken.js:45–57 + quiz.controller.js:149–151; commits bba8b06, 73d24c6.
Mermaid sequence diagram or UML diagram	§3	Rendered Mermaid PNG (mmdc + custom CSS): 6 participants, 18 numbered messages, alt/else branch for 409-replay vs 200-success.
Git history analysis: 12–15 meaningful commits, hashes + explanations	§5	14-row table with linked hashes; total corpus = 38 non-merge commits on origin/final.
Variation design-decision reflection	§4	3 numbered Review Mode decisions, each stating the rejected alternative and the reason.
Group-of-4 integration role (§11.1)	Header + §1	Subtitle cites “group-of-four mandated role, spec §11.1” verbatim.

7. Ownership boundary (per the team’s AGENTS.md local-ownership rule: Subsystem D does not silently edit A/B/C code).

Tier	Items
Owned (primary)	Response envelope + central error handler; signed attemptToken + 9-check verifier; Score.attemptId unique partial index; rate-limiters + hardening middleware (helmet / mongo-sanitize / CORS / body cap); React shell + ProtectedRoute/ProtectedAdminRoute + ActiveQuizNavigationGuard + ThemeContext; Swagger UI + Postman collection; 6 backend + 4 frontend test suites; idempotent seed + npm run demo.
Supported	Quiz-submit validation paths; forbidAdminQuiz boundary; option-order persistence on Score.answers; bulk-import per-row error envelope; Swagger annotations for routes I did not author (commits fd08cc8, d0d07f6, 4a8fe22).
Not claimed	A/Tracy: auth UI, JWT issuance, bcrypt hashing. B/Raven: quiz screens, scoring controller, Review/History/Leaderboard UI. C/Allen: admin CRUD controller and bulk-import handler logic.

8. Cross-system readiness and final reflection (spec §14, bus factor). For the demo, I can explain the parts I connected: auth (JWT lifecycle, bcrypt, generic invalid-credential message, 5/min login limiter); quiz core (\$sample 10, Fisher–Yates, attempt-token verify, reverse-mapped scoring); admin (authMiddleware + adminMiddleware, bulk-import error reporting); review/history (populate() with optionOrder reconstruction and the [Question deleted] fallback); leaderboard (best-per-user, earliest-timestamp tie-break, per Ed #175). At submission time, backend tests are 29/29, frontend tests are 13/13, the frontend build is green, and npm audit -omit=dev is clean. *Final reflection.* My main lesson from the integration role is that small API assumptions become expensive late in the project. The signed-token approach, saved optionOrder, and negative-path tests reduced that risk before the final branch was submitted.